Cryptologie Avancée (CRYPTA / MU5IN951) : examen réparti n°1

durée 2h00 / 3 pages

24 novembre 2022

Documents autorisés.

L'utilisation de tout matériel électronique (en dehors d'une montre non connectée) est interdite.

Il y a deux parties indépendantes.

Une rédaction claire et concise sera appréciée. **Toute affirmation devra être justifiée.**

Une question non résolue n'empêche pas de faire les suivantes. (dans ce cas indiquez clairement que vous admettez le(s) résultat(s) de la question non faite).

Toutes les questions valent autant de points. Le sujet est sûrement trop long. Traitez en priorité les questions que vous préférez.

Cryptanalyse de PRNG "classiques"

Soit p un (grand) nombre premier, et $k < p$. On considère deux générateurs pseudo-aléatoires "classiques". Le premier, qu'on appelle BBS, est une variante de celui proposé par Lenore Blum, Manuel Blum et Michael Shub en 1986 :

$$X_{i+1} \leftarrow {X_i}^2 \bmod p \qquad \text{et} \qquad Y_i \leftarrow \lfloor X_i/k \rfloor$$

La graine du PRNG est X_0 et la séquence de se sorties est $Y_1, Y_2, \ldots$

Le second (qu'on appelle BHHG) est une variante d'une idée proposée en 2001 par Dan Boneh, Shai Halevi et Nick Howgrave-Graham.

$$U_i = (s+i)^{-1} \bmod p \qquad \text{et} \qquad V_i = U_i \bmod k$$

La graine est s et la séquence de ses sorties est $V_1, V_2, \ldots$

Question 1 : Dans les deux cas, les sorties (Y_i et V_i) sont des versions "tronquées" d'un "état interne" (X_i et U_i). Indiquer pour les deux PRNG s'il s'agit des bits de poids fort ou bien de poids faible.

Question 2 : Pour les deux PRNG, donner la taille (en bits) des sorties Y_i et V_i.

Question 3 : Donner le nombre minimal de sorties qu'il faut connaître pour pouvoir espérer récupérer la graine (même si on dispose d'une puissance de calcul illimitée).

Question 4 : On suppose qu'on réalise les opérations arithmétiques avec les algorithmes "classiques" (ceux qu'on apprend à l'école primaire). Pour chacun des deux PRNG, combien faut-il en moyenne d'opérations élémentaires pour produire chaque bit de la sortie ?

On s'intéresse à des attaques sur ces deux générateurs qui exploitent deux sorties successives.

Question 5 : Pour BBS, on écrit $X_i = kY_i + S_i$ (où S_i est la partie "tronquée" qui est inconnue). Écrivez une équation de la forme $aS_i + bS_{i+1} + cS_i^2 \equiv d \bmod p$, avec $|S_i| \leq e$ et $|S_{i+1}| \leq e$. Exprimez a, b, c, d, e en fonction de ce qui est connu.

Question 6 : Pour BHHG, démontrer qu'on a $U_i \equiv (U_i + 1) \cdot U_{i+1} \bmod p$.

Question 7 : On écrit $U_i = V_i + kT_i$ (où T_i est la partie "tronquée"). Déduisez de la question précédente une équation de la forme $aT_i + bT_{i+1} + cT_iT_{i+1} \equiv d \bmod p$ avec $|T_i| \leq e$ et $T_{i+1} \leq e$. Exprimez là aussi a, b, c, d, e en fonction de ce qui est connu).

Dans les deux cas, on se retrouve avec une équation non-linéaire en plusieurs variables modulo p, avec une borne sur la valeur absolue des variables. Une technique assez simple et qui donne parfois de bons résultats consiste à *linéariser* le problème, c'est-à-dire à remplacer le terme non-linéaire pénible (S_i^2 ou T_iT_{i+1}) par une nouvelle variable W_i. On obtient donc dans les deux cas une équation en trois variables (x, y, z) modulo p de la forme :

$$\begin{aligned} ax + by + cz &\equiv d \bmod p \qquad (d \neq 0) \qquad (*) \\ |x| &\leq e \\ |y| &\leq e \\ |z| &\leq e^2 \end{aligned}$$

Pour résoudre $(*)$, on considère le réseau $\mathcal{L}$ engendré par les lignes de la matrice :

$$M = \begin{pmatrix} e^3 & & & e^4 a \\ & e^3 & & e^4 b \\ & & e^2 & e^4 c \\ & & & e^4 p \end{pmatrix}$$

Question 8 : Quel est le volume de $\mathcal{L}$?

Question 9 : Quelle est, de manière approximative, la norme du vecteur le plus court de $\mathcal{L}$?

Question 10 : Dans le réseau $\mathcal{L}$, le vecteur "cible"

$$\mathbf{t} = (x, y, z, k)M = (e^3 x, e^3 y, e^2 z, e^4 d)$$

est inconnu (mais il révèle une solution de l'équation). Il est *proche* du vecteur $\mathbf{c} = (0, 0, 0, \gamma d)$, qui lui est connu. Quelle est la distance entre les deux ?

Question 11 : À quelle condititition e doit-il obéir pour que $\mathbf{t}$ soit le point du réseau le plus proche de $\mathbf{c}$?

Question 12 : Décrivez une procédure qui renvoie une solution de $(*)$. Fonctionne-t-elle si $d = 0$?

Question 13 : En exploitant cette procédure, expliquez quels choix de p et k sont faibles pour les deux PRNG décrits au début.

Chiffrement par bloc

L'entreprise pour laquelle vous travaillez s'apprêtait à sortir un nouveau produit basé sur l'AES. Malheureusement, au dernier moment, le conseil d'administration a décidé un plan massif de réduction des coûts. Un génie a alors eu l'idée brillante de retirer toutes les S-boites de l'AES, sauf une (celle qui agit sur le premier octet, celui qui est en haut à gauche).

En d'autres termes, l'opération SubBytes est décrite par

$$\begin{pmatrix} a & b & c & d \\ e & f & g & h \\ i & j & k & l \\ m & n & o & p \end{pmatrix} \longrightarrow \begin{pmatrix} S(a) & b & c & d \\ e & f & g & h \\ i & j & k & l \\ m & n & o & p \end{pmatrix}$$

Toutes les autres opérations (ShiftRows, MixColumn, ...), sont identiques à celles de l'AES original, tout comme le nombre de tours.

Vous n'êtes évidemment pas à l'aise avec cette modification, que vous suspectez fortement d'avoir un impact négatif sur la sécurité. Cependant votre $N + 1$, lui, trouve ça parfait. Au fur-et-à-mesure des années, vous avez appris que le meilleur moyen de poser des problèmes à votre entreprise est de faire exactement ce que votre chef vous dit de faire. Cependant il vous reste encore un peu de conscience professionnelle et vous cherchez à affuter vos argument pour convaincre qu'on se dirige tout droit vers un accident industriel.

On s'intéresse à des attaques différentielles. On suppose que si une différence non-nulle entre dans la S-boite, alors presque toutes les différences sont possibles en sortie.

On commence par une attaque très simple. On chiffre deux messages quelconques et on "devine" la différence en sortie de la S-boite lors de chacun des 10 tours.

Question 14 : Montrer que si on devine correctement les 10 octets en question, alors on peut déterminer complètement la différence entre les chiffrés.

Question 15 : Déduisez-en une procédure qui distingue ce chiffrement par bloc d'une permutation aléatoire en moins de 2^{128} opérations.

On va maintenant essayer d'améliorer la complexité de cette attaque de base, pour la rendre plus dangereuse.

Question 16 : Suivez la progression des différences lorsqu'on chiffre deux messages qui ne diffèrent que sur un seul octet (choisissez lequel). Faites des dessins.

Question 17 : Sur la base de la question précédente, proposez une amélioration de l'attaque de base où il suffit de "deviner" *strictement moins* de 10 octets.

Pour une valeur de x quelconque, on note

$$\Delta_x = \begin{pmatrix} 0 & 0 & 0 & x \\ 0 & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \end{pmatrix}$$

On sait par ailleurs qu'il existe une paire de différences pour la S-boite (α, β) telle que $\Pr(S(x) + S(x + \alpha) = \beta) = 2^{-6}$. Autrement dit, si on a la différence α en entrée de la S-boite, on a une probabilité $1/64$ d'avoir la différence β en sortie.

Question 18 : Démontrez qu'il y a un x tel que si on a la différence Δ_x en entrée du chiffrement, alors la probabilité d'obtenir la *même* différence Δ_x au bout de 4 tours est de 2^{-6}.

Question 19 : Déduisez-en une charactéristique différentielle qui traverse les 10 tours avec probabilité 2^{-12}.

Question 20 : Ceci conduit-il à une attaque dévastatrice en pratique ?

Correction

1 Cette discussion est plus facile si $k = 2^\ell$ est une puissance de 2. En effet, alors pour BBS Y_i donne les $n - \ell$ bits de poids fort de X_i (les ℓ bits de poids faible sont masqués). Et pour BHHG, le modulo k donne les ℓ bits de poids faible (les $n - \ell$ bits de poids fort sont masqués).

Maintenant, si k est un entier quelconque. Pour BBS, l'effet de l'opération $\lfloor X_i/k \rfloor$ est de diviser l'intervalle $[0; p[$ en p/k "tranches" de taille k. Le résultat indique dans quelle tranche X_i se trouve. Par exemple, X_i et $X_i + 1$ ont une forte probabilité d'être dans la même tranche.

Pour BHHG, l'opération "modulo k" revient à garder seulement le chiffre le moins significatif "en base k". U_i et $U_i + 1$ donnent forcément deux valeurs de V_i différentes.

2 Pour BHHG, les V_i sont de taille $\lceil \log_2 k \rceil$ bits, car ils sont inférieurs à k (vu la réduction modulo k).

Pour BBS, les Y_i sont inférieurs à p/k. En effet, on a

$$Y_i = \lfloor X_i/k \rfloor \leq X_i/k \leq p/k$$

car $X_i < p$.

3 On veut reconstituer une graîne de $n \approx \log_2 p$ bits. Pour BBS, chaque sortie révèle $\approx \log_2 p - \log_2 k$ bits d'information dans le meilleur des cas. Donc il faut au moins $\log p/(\log_2 p - \log k)$ sorties pour que la graine soit uniquement déterminée. Plus k augmente (plus on tronque), plus c'est dur.

Pour BHHG, le même raisonnement montre qu'il faut au moins $\log p/\log k$ sorties (moins on tronque, plus c'est facile).

4 Pour BBS, calculer une sortie nécessite une multiplication et deux divisions. Avec les algorithmes classiques, cela prend un temps $\mathcal{O}\left(\log^2 p\right)$. La sortie fait $\approx \log_2 k$ bits, donc asymptotiquement, cela prend un temps $\mathcal{O}\left(\log^2 p/\log k\right)$ opérations par bit produit.

Pour BHHG, c'est plus compliqué à cause de l'inversion modulaire. En fait, on peut exécuter l'algorithme d'Euclide étendu sur des nombres de n bits en temps $\mathcal{O}\left(n^2\right)$ —on retombe alors sur la même chose que BBS— mais ce n'est pas complètement évident. Si on calcule l'inverse grâce au petit théorème de Fermat (avec $x^{-1} \equiv x^{p-2} \bmod p$), alors la complexité de l'inversion est $\mathcal{O}\left(n^3\right)$. Dans ce cas, on obtient $\mathcal{O}\left(\log^3 p/\log k\right)$ opérations par bit produit.

5 On a (modulo p)

$$\begin{aligned} kY_i + S_{i+1} &= X_{i+1} \\ &= X_i^2 \\ &= (kY_i + S_i)^2 \\ & k^2Y_i^2 + 2kY_iS_i + S_i^2 \end{aligned}$$

Donc si on réorganise un peu :

$$2kY_iS_i - S_{i+1} + S_i^2 = kY_i - k^2Y_i^2$$

Enfin, on sait que les S_i (les parties tronquées) sont inférieures à p/k.

6 On a (toujours modulo p) :

$$\begin{aligned} U_i &= (s+i)^{-1} & U_{i+1} &= (s+i+1)^{-1} \\ U_i^{-1} &= s+i & U_{i+1}^{-1} &= (s+i+1) \end{aligned}$$

Donc :

$$\begin{aligned} U_{i+1}^{-1} - U_i^{-1} &= 1 \\ U_{i+1}^{-1} &= 1 + U_i^{-1} \end{aligned}$$

Et là on multiplie par U_iU_{i+1} pour obtenir ce qu'on voulait :

$$U_i = U_iU_{i+1} + U_{i+1}$$

7 L'équation de la question précédente se traduit (modulo p) par :

$$V_i + kT_i = (V_i + kT_i + 1)(V_{i+1} + kT_{i+1})$$

On développe, on regroupe les termes en T_i, et on trouve :

$$\begin{aligned} V_i + kT_i &= (V_i + kT_i + 1)(V_{i+1} + kT_{i+1}) \\ &= V_i(V_{i+1} + kT_{i+1}) + kT_i(V_{i+1} + kT_{i+1}) + (V_{i+1} + kT_{i+1}) \\ V_i - V_iV_{i+1} - V_{i+1} &= k(V_{i+1} - 1)T_i + k(V_i + 1)T_{i+1} + k^2T_iT_{i+1} \end{aligned}$$

Et c'est ça qu'on voulait (ceci est vrai modulo p).

8 La matrice est carrée, donc le volume est son déterminant. Elle est triangulaire, donc c'est le produit des coefficients diagonaux. Le volume est donc $e^{12}p$.

9 Par l'heuristique gaussienne, on trouve que $\lambda_1(\mathcal{L}) \approx vol(\mathcal{L})^{1/4} = 2e^3p^{1/4}$

10 La distance entre les deux est exactement $\sqrt{e^6x^2 + e^6y^2 + e^4z^2}$ et vu les bornes sur x, y, z, on trouve que ceci est inférieur à e^4.

11 Il faut que la distance entre les deux soit inférieure à (la moitié de) la norme du plus court vecteur. Cela se traduit par $e^4 \lll e^3p^{1/4}$ (on oublie les facteurs constants), et en simplifiant on trouve $e \leq p^{1/4}$. Concrètement, pour nos PRNGs, il faut que la partie tronquée représente moins du quart de la taille de l'état interne, sinon cette technique ne fonctionne plus.

12 On construit la matrice M. On résout CVP avec la cible $(0, 0, 0, e^4d)$. C'est calculatoirement facile car le réseau n'est que de dimension 4. On obtient le vecteur (e^3x, e^3y, e^2z, e^4d) (on peut vérifier qu'on obtient bien e^4d sur la dernière coordonnée). On reconstitue x, y, z en divisant les trois premières coordonnées par les bonnes puissances de e.

13 Ceci montre qu'on peut reconstituer l'état interne de nos deux PRNGs avec seulement deux sorties successives, tant que la proportion des bits qui nous sont « cachés » lors de chaque sortie est inférieure à $1/4$. Il faut donc tronquer plus de 25% des bits pour espérer obtenir une forme de sécurité (mais ceci ne prouve pas que ce sera suffisant...).

16 Cela revient à chiffrer deux blocs dont la différence est :

$$\begin{pmatrix} x & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \end{pmatrix}$$

Après 1 tour on a :

$$\begin{pmatrix} 0 & 0 & 0 & 0 \\ y & 0 & 0 & 0 \\ 0 & 0 & 0 & 0 \\ y & 0 & 0 & 0 \end{pmatrix}$$

Après 2 tours on a :

$$\begin{pmatrix} 0 & y & 0 & 0 \\ 0 & 0 & 0 & 0 \\ 0 & 0 & 0 & y \\ 0 & 0 & 0 & 0 \end{pmatrix}$$

Après 3 tours on a :

$$\begin{pmatrix} 0 & y+z & 0 & 0 \\ 0 & z & 0 & 0 \\ 0 & y & 0 & 0 \\ 0 & y+z & 0 & 0 \end{pmatrix}$$

Après 4 tours on a :

$$\begin{pmatrix} 0 & t & y+z & y \\ 0 & t & 0 & 0 \\ z & 0 & 0 & y \\ 0 & t & 0 & y \end{pmatrix}$$

Après 5 tours on a :

$$\begin{pmatrix} y & u+y & v & w \\ 0 & y & 0 & 0 \\ t & y & z & 0 \\ 0 & 0 & t & 0 \end{pmatrix}$$

Etc. 6 tours doivent suffire.